CVE Decaf:

Brewing Better and More Actionable Vulnerablity Data

VulnCon 2026 · A Co-Presentation

Jay Jacobs

Empirical Security Data Science & Statistical Modeling

Jerry Gamblin

RogoLabs Vulnerability Intelligence Engineering

> **“Quality is not a property. It is a relationship with a task.”**

THE MORNING ORDER

The Caffeine Jitters

The Scale Problem

The CVE corpus is growing at a rate of **one new record every ten minutes.** At over 326,000 records and climbing, this is no longer a data problem — it's a signal-to-noise crisis. Scale is the new adversary. When volume overwhelms review capacity, quality becomes the determining factor in whether security workflows produce correct outputs — or **"confident-looking failures."**

326K+

CVE Records
Total published and growing daily

150+ CVEs A Day

New Record Rate
One new CVE every ten minutes

SECTION 1: ONTOLOGICAL FOUNDATION

Foundations:

Statistical Quality Control (1920s–1960s)

Walter Shewhart (1931): *Economic Control of Quality of Manufactured Product*

- Quality must be defined operationally and measured against specification

W. Edwards Deming (1950s–1980s): *Out of the Crisis*

- Emphasis on systemic causes of defects (rather than blaming individuals)

Joseph Juran (1951): *Quality Control Handbook*

- Fitness for use

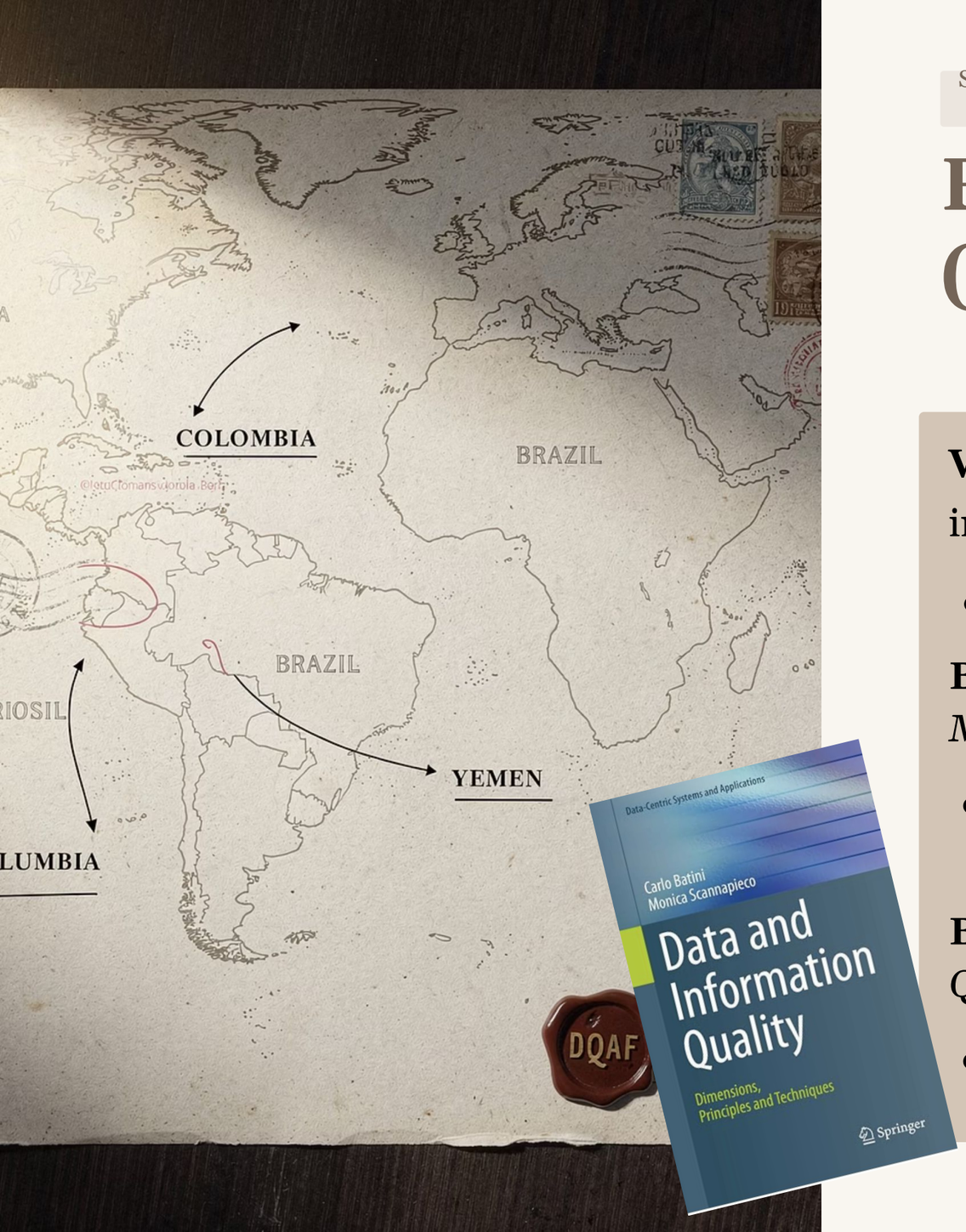
Data Quality:

Becomes Its Own Field (1990s)

Richard Y. Wang and Diane M. Strong (1996): *Beyond Accuracy: What Data Quality Means to Data Consumers*

- Conducted an *empirical study* that produced a hierarchical framework of data quality dimensions as perceived by data consumers
- "We define data quality as *data that are fit for use by data consumers*."

Category	Dimensions
Intrinsic	Accuracy, Objectivity, Believability, Reputation
Contextual	Relevancy, Value-Added, Timeliness, Completeness, Appropriate Amount
Representational	Interpretability, Ease of Understanding, Conciseness, Consistent Representation
Accessibility	Accessibility, Access Security



Frameworks and Taxonomies (1990s–2000s)

Wand and Wang (1996): Anchoring Data Quality Dimensions in Ontological Foundations

- Should be grounded in formal ontology rather than empirical surveys

Batini, Cappiello, Francalanci, and Maurino (2009): *Methodologies for Data Quality Assessment and Improvement*

- Reviewed and compared 13 DQ assessment methodologies across multiple dimensions

Batini and Scannapieco (2006 / 2016): *Data and Information Quality: Dimensions, Principles and Techniques*

- The standard textbook

Standardization Efforts (2000s–2010s)

ISO/IEC 25012:2008: *Software Engineering: Software Product Quality Requirements and Evaluation (SQuaRE)*

- Defines 15 data quality characteristics

ISO 8000 Series: *Data Quality Series*

- An evolving family of standards focused on data quality, data exchange, and data quality management.

IMF Data Quality Assessment Framework (DQAF)

- Specifically for assessing the quality of macroeconomic statistics

The Foundations.

Juran: **Fitness for use**

- Quality of a data record depends on *what decisions it must support*.

Wang & Strong: **Intrinsic vs. contextual vs. representational vs. accessibility**

- Provides a ready-made dimensional structure to classify data quality issues.

Wand & Wang: **Ontological grounding**:

- Connects to the philosophical framing: are the *categories themselves* well-formed?

Wang: **Information as product**:

- Treats information as manufactured products with definable quality characteristics, process controls, and defect rates.

The IMF DQAF model:

- A domain-specific quality framework with institutional authority.

The DQAF Process

01. Consumer Scoping

Identify consumer roles and tasks — quality is relational; define who uses the data and for what.

02. Requirement Definition

Identify required data elements per task — what fields must be present for each task to succeed.

03. Dimension Selection

Select applicable IQ dimensions per task — not all dimensions apply equally; match dimensions to task needs.

04. Metric Operationalization

Operationalize metrics per dimension–task pair — task-specific measures, not generic ones.

05. Corpus Measurement

Measure against the corpus — field population rates, consistency, conditional completeness.

06. Root Cause Analysis

Analyze root causes — distinguish population gaps (records don't) from design gaps (schema cannot).

07. Intervention Specification

Specify interventions: population gaps → producer guidance/enrichment; design gaps → schema evolution.

Today's Pour — Four Consumer Tasks

A consumer-grounded evaluation of CVE data quality across the tasks that actually matter.

Identification

Is this vulnerability present in my environment, my product, or my dependencies?

Characterization

What exactly is this vulnerability, technically, and what can be done with it?

Remediation

How urgently should I act on this vulnerability relative to others?

Prioritization

What specific action should I take to address this vulnerability?

Identification

Is this vulnerability present in my environment, my product, or my dependencies?

- Asset-to-vulnerability matching (automated)
- Supply chain dependency checking
- Duplicate detection
- Applicability determination

Characterization

What exactly is this vulnerability, technically, and what can be done with it?

- Detection signature development
- Exploit development / PoC creation
- Vulnerability explanation / advisory writing
- Impact assessment
- Root cause classification

Remediation

How urgently should I act on this vulnerability relative to others?

- Patch identification and application
- Workaround implementation
- Mitigation rule creation

Prioritization

What specific action should I take to address this vulnerability?

- Global Prioritization
- Local Prioritization

ROAST PROFILES

Population Gap (PG)

The schema **can** express the required information (the field exists, the mechanism is in place), but the records simply don't contain it.

Design Gap (DG)

The schema has **no mechanism** to express what the task requires, or the existing mechanism is structurally insufficient regardless of CNA diligence.

Ecosystem Constraint (EC)

The gap **cannot be addressed** by CVE record improvements alone because prerequisite infrastructure does not exist in the ecosystem.

Organization Knowledge (OK)

Limited to “local” knowledge outside the scope of any global system

Identification

Is this vulnerability present in my environment, my product, or my dependencies?

- Identification presence in the record PG
- Matching to the technology estate EC
- Version evaluability DG

Characterization

What exactly is this vulnerability, technically, and what can be done with it?

- Detection signature development
- Exploit development / PoC creation
- Vulnerability explanation / advisory writing
- Impact assessment
- Root cause classification

Remediation

How urgently should I act on this vulnerability relative to others?

- Patch identification and application
- Workaround implementation
- Mitigation rule creation

Prioritization

What specific action should I take to address this vulnerability?

- Global Prioritization
- Local Prioritization

Identification

Is this vulnerability present in my environment, my product, or my dependencies?

- Identification presence in the record PG
- Matching to the technology estate EC
- Version evaluability DG

Characterization

What exactly is this vulnerability, technically, and what can be done with it?

- Date of public disclosure PG
- Nature of the fault (weakness) PG
- Fault Location (Component) PG
- The exploitation conditions DG
- Security consequence DG

Remediation

How urgently should I act on this vulnerability relative to others?

- Patch identification and application
- Workaround implementation
- Mitigation rule creation

Prioritization

What specific action should I take to address this vulnerability?

- Global Prioritization
- Local Prioritization

Identification

Is this vulnerability present in my environment, my product, or my dependencies?

- Identification presence in the record PG
- Matching to the technology estate EC
- Version evaluability DG

Characterization

What exactly is this vulnerability, technically, and what can be done with it?

- Date of public disclosure PG
- Nature of the fault (weakness) PG
- Fault Location (Component) PG
- The exploitation conditions DG
- Security consequence DG

Remediation

How urgently should I act on this vulnerability relative to others?

- Fix Information PG
- Workaround/Mitigations PG

Prioritization

What specific action should I take to address this vulnerability?

- Global Prioritization
- Local Prioritization

Identification

Is this vulnerability present in my environment, my product, or my dependencies?

- Identification presence in the record PG
- Matching to the technology estate EC
- Version evaluability DG

Characterization

What exactly is this vulnerability, technically, and what can be done with it?

- Date of public disclosure PG
- Nature of the fault (weakness) PG
- Fault Location (Component) PG
- The exploitation conditions DG
- Security consequence DG

Remediation

How urgently should I act on this vulnerability relative to others?

- Fix Information PG
- Workaround/Mitigations PG

Prioritization

What specific action should I take to address this vulnerability?

- Global Prioritization (see Identification/ Characterization)
- Local Prioritization OK

Discussion Items

Completed “Proof of Value”

- The Vulnerabilty Naming System Must Come First
- The Identification Failure Is a Big Deal
- Failures Cascade in the Dependency Order of the Tasks
- The Scaling Problem the Corpus Cannot See (“Lord’s Automation Test”)
- Towards a Consumer-Grounded Quality Standard

Thank You

Access the full research paper and slide deck:

github.com/CVEDQAF/VulnCon2026